Lab 5: Static Code Analysis

Priyanka B M | SRN: PES1UG24AM207 | Assigned script: `tower_maintenance.py` (repo `L5_25_tower_maintenance`) | Submission repo: https://github.com/priyankabm11/PES1UG24AM207_SE (folder `Lab-5`)

1. Objective

In this lab I ran three static analysis tools on the Python script assigned to me: Pylint for code quality, Bandit for security and Flake8 for PEP 8 style. The goal was to look at what each tool reported, fix the problems, and re-run the tools to check that the reports came out clean.

2. Setup and Approach

- I set up a Python 3.12.9 virtual environment on macOS and installed Pylint 4.1.3, Bandit 1.9.4 and Flake8 7.4.1 with pip.
- I ran the original script first. It printed `['Ridge-A'] high 2 1`, so I used that as my reference and checked it again after every change.
- Then I generated the "before" reports and fixed the issues one tool at a time, making one commit per tool and re-running the tools each time.

3. Summary of Results

Here is how the three reports changed after my fixes.

Tool	Before	After
Pylint	5.14 / 10	10.00 / 10
Bandit	4 issues (2 Medium, 2 Low, 0 High)	0 issues
Flake8	7 issues	0 issues

4. Issues Found and Fixes

Line numbers refer to the original script.

4.1 Bandit (security)

Issue	Type	Line(s)	Description	Fix approach
B608 SQL injection (Medium)	Security	11	The INSERT query was built with % string formatting, so a crafted site name could change the SQL.	Switched to a parameterised query with ? placeholders.
B301 pickle deserialisation (Medium)	Security	43	`snapshot()` ran `pickle.loads(pickle.dumps(...))` on the query result. Pickle is unsafe with untrusted data, and the round trip wasn't needed anyway.	Just returned the `fetchall()` result.
B403 pickle import (Low)	Security	1	Importing pickle gets flagged as a risk.	Removed the import once pickle was no longer used.
B105 hardcoded password (Low)	Security	6	`NOC_PASSWORD` was a plain string sitting in the source code.	Now read from an environment variable with `os.environ.get`.

4.2 Pylint (code quality)

Issue	Type	Line(s)	Description	Fix approach
C0114 / C0116 missing docstrings	Convention	1, 10, 15, 25, 34, 42, 46	The module and every function were missing a docstring.	Added a module docstring and a short docstring for each function.

Issue	Type	Line(s)	Description	Fix approach
C0103 invalid names	Convention	7, 10, 15, 34	`addTower`, `serviceTower` and `riskLevel` weren't snake_case, and `service_count` is a module-level constant so it should be UPPER_CASE.	Renamed them to `add_tower`, `service_tower` and `risk_level`, updated every call, and replaced the counter with STATS.
W0603 global statement	Warning	16	`serviceTower` changed a module-level variable using `global`.	Kept the counter in a dictionary, `STATS["service_count"]`, so `global` isn't needed.
W0718 broad exception	Warning	20	`except Exception` can hide errors that have nothing to do with the database.	Now catches `sqlite3.Error` only.
R1705 no-else-return	Refactor	36	There was an `else` right after a `return` in `riskLevel`.	Removed the `else` and de-indented the last return.
C0209 consider f-string	Convention	11	A regular string was being formatted by hand.	Went away with the Bandit fix, since the query is now parameterised.
C0301 line too long	Convention	5, 11, 18	These lines went over Pylint's 100 character limit.	Split the long statements across several lines.

4.3 Flake8 (style)

Issue	Type	Line(s)	Description	Fix approach
E501 line too long (over 79 characters)	Style	5, 11, 18, 35, 43	Five lines were longer than 79 characters.	Wrapped them. Lines 5, 11, 18 and 43 were already fixed in the Bandit and Pylint commits, and line 35 was wrapped in the Flake8 commit.
E303 too many blank lines	Style	25	There were three blank lines before `overdue`.	Cut it down to two.
E225 missing whitespace around operator	Style	50	`total=len(snapshot())`.	Changed to `total = len(snapshot())`.

5. Commits

Commit	Purpose
`f2c9bf1`	Baseline: original script and the three "before" reports
`177f15f`	Fix Bandit issues: parameterised SQL, remove pickle, environment-based password
`26aab12`	Fix Pylint issues: docstrings, naming, no global, specific exception
`24ca1ef`	Fix Flake8 style issues

The Bandit, Pylint and Flake8 commits are my three fix commits. The baseline commit just stores the original script and the "before" reports, and each fix commit also includes the matching "after" report.

6. Verification

After the last commit I re-ran all three tools. Pylint gave 10.00/10, Bandit found 0 issues at every severity and confidence level, and the Flake8 report came out empty. The program still prints `['Ridge-A'] high 2 1`, so my changes didn't alter what it does.

7. Reflection

What stood out to me is that the program ran fine before I touched it, yet Bandit still found real security problems. The SQL built with string formatting and the pointless pickle round trip never caused an error, but they would be risky with untrusted input. So "it works" and "it's safe" turned out to be two different things.

The tools also cover different ground. Bandit looks at security, Pylint at design and readability (naming, docstrings, global state, broad exceptions), and Flake8 at formatting. Some fixes helped more than one

tool, like the parameterised query, which cleared a Bandit warning and a Pylint warning at once.

A few fixes needed actual thinking. Wrapping long lines is mechanical, but replacing the global counter and picking the right exception to catch meant I had to understand what the code was doing. I ran the program after each commit to make sure the output stayed the same.

I think running these tools regularly, for example before every commit, would catch mistakes early and keep code consistent. They aren't a replacement for testing and code review though, because a clean report doesn't prove the program is correct.

8. Files Submitted

Everything is in the `Lab-5` folder of my submission repo: `tower_maintenance.py` (updated), `pylint_report_before.txt`, `pylint_report_after.txt`, `bandit_report_before.txt`, `bandit_report_after.txt`, `flake8_report_before.txt`, `flake8_report_after.txt`, and this report.